

Checklist

Unix Application Server Security

Patch and Update Management

- ☐ Keep the Unix/Linux operating system fully patched.
- ☐ Keep all third-party applications and packages up to date.
- ☐ Use the operating system's package-management system whenever possible.
- ☐ Update package repositories before installing upgrades.
- ☐ Review available updates before applying them.
- ☐ Track applications installed outside the package manager separately.
- ☐ Subscribe to security advisories for manually installed applications.
- ☐ Test important patches and upgrades before deploying them to production.
- ☐ Maintain a rollback or recovery plan before major operating-system upgrades.
- ☐ Keep update intervals small so large, disruptive upgrades are less likely.

Services and Daemons

- ☐ Inventory all running services and processes.
- ☐ Determine the purpose of each enabled service.
- ☐ Disable services that are not required.
- ☐ Prevent unnecessary services from starting automatically after reboot.
- ☐ Verify required services start correctly after configuration changes.
- ☐ Periodically recheck the server for newly enabled or unnecessary services.
- ☐ Use the system's standard service-management mechanism, such as `systemctl`, where applicable.

File and Directory Permissions

- ☐ Apply the principle of least privilege to files and directories.

- ☐ Verify ownership and group membership of sensitive files.
- ☐ Remove unnecessary world-readable permissions.
- ☐ Remove unnecessary world-writable permissions.
- ☐ Remove unnecessary execute permissions.
- ☐ Review the system `umask` and ensure new files receive appropriately restrictive permissions.
- ☐ Check files accessible by application-service accounts such as web-server users.
- ☐ Ensure application accounts cannot read data they do not require.
- ☐ Review SUID and SGID files and remove unnecessary special permissions.
- ☐ Regularly search for unexpected permission changes.

Host-Based Firewall

- ☐ Enable a host-based firewall on the server.
- ☐ Permit only network traffic required for the server's function.
- ☐ Block unnecessary inbound connections.
- ☐ Restrict administrative services to trusted networks or addresses when possible.
- ☐ Review firewall rules for obsolete entries.
- ☐ Verify firewall rules after application or network changes.
- ☐ Confirm required application traffic still works after firewall changes.

File Integrity Monitoring

- ☐ Deploy a file-integrity monitoring solution.
- ☐ Monitor critical operating-system files.
- ☐ Monitor application configuration files.
- ☐ Monitor web/application directories for unauthorized additions or modifications.
- ☐ Establish a trusted baseline of important files.
- ☐ Configure alerts for unexpected changes.
- ☐ Investigate unexplained integrity alerts promptly.
- ☐ Integrate integrity alerts with existing monitoring or logging systems where practical.

Filesystem and Disk Partition Security

- ☐ Separate sensitive or high-risk filesystem areas onto appropriate partitions where practical.
- ☐ Review `/etc/fstab` or equivalent mount configuration.

- ☐ Use `nodelv` on filesystems that should not contain device files.
- ☐ Use `nosuid` where SUID/SGID execution is unnecessary.
- ☐ Use `noexec` on data-only filesystems where executable files are not required.
- ☐ Use `ro` for filesystems that do not need to be modified.
- ☐ Verify mount-option changes after remounting or rebooting.
- ☐ Test applications after applying restrictive mount options.

SUID/SGID Review

- ☐ Identify SUID executables.
- ☐ Identify SGID executables.
- ☐ Verify that each privileged executable is necessary.
- ☐ Remove unnecessary SUID/SGID permissions.
- ☐ Pay special attention to unexpected privileged binaries outside normal system directories.

Application Isolation

- ☐ Determine whether the application can be isolated from the rest of the filesystem.
- ☐ Use `chroot`, containers, jails, or another isolation mechanism where appropriate.
- ☐ Minimize files and utilities available inside the isolated environment.
- ☐ Avoid running isolated applications as root unless absolutely required.
- ☐ Do not treat `chroot` alone as a complete security boundary.
- ☐ Test whether the application continues to function correctly after isolation.

Mandatory Access Control

- ☐ Determine whether the platform supports SELinux, AppArmor, TrustedBSD, or another MAC framework.
- ☐ Enable mandatory access control where practical.
- ☐ Apply least-privilege policies to application processes.
- ☐ Restrict application access to only required files, devices, ports, and system functions.
- ☐ Review policy violations and audit logs.
- ☐ Use permissive/audit mode during testing if necessary before enabling full enforcement.
- ☐ Regularly review policies as application requirements change.

Application Account Security

- ☐ Run each application under a dedicated non-root account where possible.
- ☐ Prevent service accounts from interactive login unless required.
- ☐ Limit service-account filesystem access.
- ☐ Restrict administrative privileges such as `sudo`.
- ☐ Remove unused accounts and groups.
- ☐ Review group memberships for excessive privileges.

Validation and Ongoing Maintenance

- ☐ Confirm the application still performs its required business functions after hardening.
- ☐ Reboot the server when required and verify all necessary services return correctly.
- ☐ Scan for unexpected listening ports.
- ☐ Review system and application logs for errors or suspicious activity.
- ☐ Test firewall, filesystem, permissions, and access-control restrictions.
- ☐ Document all security-related configuration changes.
- ☐ Maintain a record of approved exceptions.
- ☐ Back up critical configuration files.
- ☐ Periodically repeat the hardening review.
- ☐ Review the server after major application, operating-system, or infrastructure changes.

Final Security Review

- ☐ Operating system is current.
- ☐ Applications are current.
- ☐ Only required services are running.
- ☐ File permissions follow least privilege.
- ☐ Host firewall allows only required traffic.
- ☐ File-integrity monitoring is active.
- ☐ Secure filesystem mount options are applied.
- ☐ Unnecessary SUID/SGID binaries have been removed or restricted.
- ☐ Application isolation is implemented where appropriate.
- ☐ Mandatory access controls are enabled where supported.
- ☐ Security controls have been tested without breaking required functionality.

☐ Configuration and recovery procedures are documented.